

Cybersecurity for SME Employees

Module 3.5 – What to Do if You Fall for a Phish

1 Objective

Help employees respond quickly and effectively if they fall victim to a phishing attack to minimize damage and support incident response.

2 Introduction

Even the most vigilant individuals can make mistakes. Phishing attacks are designed to trick and manipulate, and falling for one doesn't mean you've failed—it means you need to act fast. This module covers the steps to take after realizing you've interacted with a phishing attempt.

3 Immediate Steps to Take

1. **Disconnect Your Device:** If you clicked a link or downloaded a file, disconnect from Wi-Fi or unplug the network cable to prevent malware from spreading.
2. **Do Not Delete the Email:** Keep the message for analysis. It helps your security team understand the threat.
3. **Report Immediately:** Notify your IT or security team as soon as possible. Speed matters.
4. **Change Passwords:** If you entered credentials, change your password immediately—especially for email, work accounts, or anything related.
5. **Enable MFA:** If multi-factor authentication is available and not yet enabled, turn it on for additional protection.

4 What to Tell Your IT/Security Team

Provide clear information:

- What you clicked or downloaded
- If you entered any data (e.g., username, password)
- When the incident occurred
- Any error messages or odd system behavior

5 Damage Control and Remediation

- IT may isolate your device to run scans or reimage the system.
- Monitor affected accounts for unauthorized activity.
- Inform clients or partners if their data might be at risk (based on company policy).
- Review access logs to check for unusual activity.

6 Learning and Recovery

- Attend a follow-up debrief to understand what happened.
- Share the experience (anonymously, if needed) so others can learn.
- Revisit phishing training or simulation exercises.
- Use the event to strengthen security awareness.

7 Psychological Impact

- It's normal to feel embarrassed or anxious—don't blame yourself.
- Cyberattacks are designed to manipulate; being fooled doesn't make you unskilled.
- Focus on taking corrective action and helping others avoid the same mistake.

8 Conclusion

If you fall for a phishing attempt, your first move is to act—not to panic. Timely reporting can save your company from serious damage. A strong security culture means supporting each other when things go wrong and always striving to do better next time.